

Phishing Investigation Writeup

Planet's Prestige — Blue Team Labs Online (BTLO)

Shubh | SOC Analyst (L1) Track

Overview

Platform: Blue Team Labs Online (BTLO)

Room: Planet's Prestige

Category: Phishing / Email Forensics / File Analysis

Status: Completed — 10/10 points

This room simulated a phishing/extortion email investigation. The scenario centered on a ransom-style email, “A Hope to CoCanDa,” sent to “TheMajorOnEarth,” demanding payment for the safe return of abducted “CoCanDians,” including a “President’s daughter.” The email included a suspicious .zip attachment and a set of embedded clues that had to be decoded and cross-referenced to progress through the investigation.

Objective

- Extract and decode hidden/encoded data
- Identify file metadata artifacts left behind by the threat actor
- Follow the clue chain (steganography-style riddles) to the final answer
- Practice the same triage steps used in real-world BEC (Business Email Compromise) / extortion phishing investigations

Tools Used

Tool	Purpose
CyberChef	Base64 decoding, encoding identification
ExifTool	File metadata extraction (JPEG, PDF)
PowerShell	Command-line file inspection on Windows
Manual OSINT / deduction	Solving embedded riddles and anagram clues

Investigation Walkthrough

1. Initial Email Triage

Reviewed the phishing email “A Hope to CoCanDa” and its headers. The message was sent using emkei.cz, a free anonymous email relay commonly abused for header spoofing, with a Reply-To address of negeja3921@pashter.com — the first indicator tying the message to an attacker-controlled domain (pashter.com) rather than a legitimate sender. The email body contained several deliberate red flags typical of extortion phishing:

- Urgency and threat framing (“abducted,” ransom demand)
- A vague, non-standard payment demand (“1 Billion CoCanDs”)
- An embedded riddle/clue left by the sender: “I’m approximately 12.8 light minutes away from the sun” — a distance clue
- A second hint: “Don’t Trust Your Eyes” — signaling that literal/visual inspection wouldn’t be enough; deeper inspection (metadata/encoding) was required

The received attachment was a .zip archive — identifying this filetype was the key that unlocked the rest of the investigation, since it contained the puzzle files analyzed in the next steps.

2. Decoding Embedded Base64 Data

Loaded the extracted data into CyberChef with a “From Base64” recipe (Remove non-alphabet chars enabled) and worked through multiple Base64-encoded blobs found across the attachment chain:

- One blob decoded back to the original phishing email text (confirming the source content)
- One blob decoded to raw binary starting with “PK” — the signature of the ZIP archive delivered as the attachment
- One blob decoded cleanly to plaintext: “The Martian Colony, Beside Interplanetary Spaceport.”

This decoded string directly matched the “12.8 light-minutes from the sun” clue in the email — Mars sits at roughly that distance from the Sun on average — confirming the attacker’s claimed location: The Martian Colony, Beside Interplanetary Spaceport.

3. Metadata Forensics with ExifTool

Extracted the files bundled with the puzzle (DaughtersCrown.jpeg, GoodJobMajor.pdf) and ran exiftool against each from PowerShell:

```
exiftool .\DaughtersCrown.jpeg
exiftool .\GoodJobMajor.pdf
```

Key findings:

- DaughtersCrown.jpeg — standard JPEG metadata, no immediately actionable EXIF artifacts beyond file timestamps
- GoodJobMajor.pdf — metadata revealed a non-default Author field: “Petero Negeja”

Given the earlier “Don’t Trust Your Eyes” hint, the Author field was treated as a deliberately planted clue rather than genuine authorship metadata. Combined with the Reply-To address from step 1, this confirmed the malicious actor’s identity as Petero Negeja, operating from the pashter.com domain.

4. Chaining the Clues

Correlating the independent artifacts collected across the investigation:

1. The email header (emkei.cz sender service, negeja3921@pashter.com Reply-To)
2. The email's riddle (distance + “don't trust your eyes”)
3. The CyberChef-decoded location string (Martian Colony)
4. The ExifTool-extracted PDF metadata (Author: Petero Negeja)

...built the full picture needed to answer every question in the room and identify pashter.com as the probable command-and-control (C&C) domain the attacker would use to control their claimed “autonomous bots,” since it was the only attacker-owned domain surfaced across headers and metadata. This completed the investigation with a full score, culminating in the “Planet's Prestige” achievement.

Challenge Submission Summary

All submitted answers were verified correct:

Question	Answer
What is the email service used by the malicious actor? (1 pt)	emkei.cz
What is the Reply-To email address? (2 pts)	negeja3921@pashter.com
What is the filetype of the received attachment which helped continue the investigation? (1 pt)	.zip
What is the name of the malicious actor? (2 pts)	Petero Negeja
What is the location of the attacker in this Universe? (2 pts)	The Martian Colony, Beside Interplanetary Spaceport
What could be the probable C&C domain to control the attacker's autonomous bots? (2 pts)	pashter.com

Indicators of Compromise (IOCs)

Indicator	Value
Sender email service	emkei.cz (anonymous email relay)
Reply-To address	negeja3921@pashter.com
Attacker alias	Petero Negeja
Probable C&C domain	pashter.com
Claimed attacker location	The Martian Colony, Beside Interplanetary Spaceport
Malicious attachment filetype	.zip

Key Skills Demonstrated

- Phishing email header/body triage, including sender-service and Reply-To analysis
- Identifying and decoding multi-layer Base64-encoded payloads
- File signature recognition (“PK” → ZIP-based format) from raw decoded bytes
- File metadata forensics using ExifTool across image and PDF formats
- Logical/OSINT-style clue correlation across independent artifacts
- Deriving a probable C&C domain from header and metadata evidence

Lessons Learned

- Phishing payloads increasingly hide meaningful data inside encoding layers, not just attachments — decoding every layer matters, not just the first.
- File metadata (Author, timestamps, producer fields) is a cheap but frequently overlooked source of attacker-left artifacts.
- Investigation clues rarely arrive in isolation — cross-referencing independent data points (headers, decoded strings, metadata) is often required to reach a conclusion, mirroring real SOC/DFIR triage where no single log tells the whole story.

Writeup by Shubh — SOC Analyst (L1) Track